SecurityPal

Vendor Assessment Report

Third-Party Security & Risk Management Analysis

2026-03-01

Name of Vendor → Grant LLC

Overall Risk Rating → Low

Table of Contents

Executive Summary **3**
Vendor Profile **4**
Vendor Product & Service Information 4
Purpose **5**
Vendor Assessment Scope of Work **6**
Risk Assessment Approach **8**
Risk Assessment Findings **11**
Documentation Review 12
Identified Risks 12
Exceptions Noted **14**
Recommendation **15**
Conclusion **16**

Executive Summary

A comprehensive risk assessment of Grant LLC was completed on 2026-03-01. The vendor is aligned with the specific business requirements and security standards of the client. It is recommended that CompanyX **approve Grant LLC**. However, the identified risks must be effectively managed through strategic mitigation measures.

Key Findings:

- Alignment: Policies are formally documented and reviewed annually by the CISO.
- Data Handling: The vendor has specific capabilities for de-identification (SI-19), matching the bank's requirement for de-identified experimental data.
- Access Control: Strong enforcement of Least Privilege (AC-6) and Separation of Duties (AC-5).

#	Section name	Risk Description	Risk Rating
GRC Risk			
1.		1. Absence of Independent Third-Party Assurance (SOC 2/ISO 27001): While the vendor has robust internal policies aligned with NIST SP 800-53, they have not provided independent audit reports such as SOC 2 Type 2 or ISO 27001. For a highly regulated British bank, relying solely on self-attested policies without external validation of operating effectiveness represents a significant oversight gap.	Moderate (9)
		2. Incomplete Personnel Screening (Credit History): The Personnel Security Policy (COM-POL-PSP-14) mandates criminal and employment checks but does not explicitly include credit history verification. Given the financial nature of the integration, staff with access to banking systems should undergo financial stability screening to mitigate insider threat risks related to fraud or coercion.	Moderate (9)
		3. Regulatory Alignment Ambiguity (UK/EU specific): The vendor's framework is heavily based on US NIST standards. There is no documented evidence of alignment with UK-specific financial regulations (such as FCA handbook requirements) or a mapping of controls to the UK/EU regulatory environment, which is essential for a British bank's compliance.	Moderate (6)
		4. Lack of Formal Data Flow Mapping: Although the Configuration Management Policy mentions "data action mappings", no actual Data Flow Diagram (DFD) was provided. Without a visual representation of how	Moderate (6)

		bank data moves between systems and FinTech platforms, the bank cannot fully assess the technical "attack surface" of the integration.	
Data Privacy Risk			
1.		1. Lack of Global Privacy Certifications (ISO 27701/GDPR): The vendor does not participate in recognized privacy programs or hold certifications like ISO/IEC 27701. For an integration involving authentic transaction data, the absence of a certified Privacy Information Management System (PIMS) increases the risk of non-compliance with UK GDPR.	Moderate (9)
		2. Transparency Gap in Law Enforcement Data Access: Grant LLC does not provide specific public guidelines or a transparency report regarding how they handle law enforcement requests for customer data. This lack of transparency is a risk for financial institutions that must ensure customer data is only disclosed under strict legal conditions.	Moderate (6)
		3. Unverified De-identification Effectiveness: The vendor claims capabilities for de-identification (SI-19), which aligns with the bank's project needs. However, there is no third-party validation or technical whitepaper provided to prove that their anonymization techniques meet the "irreversibility" standards required by data protection authorities.	Moderate (6)
		4. Ambiguous Data Residency and Sovereignty: The sources mention the use of cloud-based components but do not specify the geographic locations of data centres. If transaction data is stored or processed outside the UK/EEA, it may trigger additional legal requirements (like SCCs) that have not been addressed in the provided documentation.	Moderate (9)
		5. Restricted Data Destruction Rights: The vendor indicates that data will be destroyed according to the contract rather than immediately "on demand" by the client. This could conflict with the bank's need for absolute control over experimental datasets once testing phases are completed.	Low (3)

Essential documentation has been tabulated below:

Description	Status	Provided by Vendor (Yes/No/N/A)
ISO 27001 Certification	Certified/Not Certified	NO
SOC 2 Type 2 Attestation	Attested	Yes
Information Security Policies	Provided	Yes
Risk Management Program	Established	Yes
Personnel Security Policy (includes NDAs/AUP)	Mandated by Policy	Yes
Incident Response Plan	Defined in Policy	Yes
Data Privacy / De-identification Policy	Defined in SI-19	Yes
Configuration Management Policy	Provided	Yes
Penetration Testing Report	Not Completed	No
Data Flow Diagram (DFD)	Not Uploaded	No

Additional Findings

- Data Destruction Limitations: Personnel policies and vendor responses indicate that customer data will not be destroyed "on demand" by the client. Instead, data disposal is strictly governed by the specific timelines and conditions established in the individual client contract.
- Privacy Roadmap (ISO 27701): Grant LLC does not currently participate in any formal privacy programs or hold privacy-specific certifications. They have placed the ISO/IEC 27701 standard (Privacy Information Management) on their roadmap for the next certification audit scheduled to begin in April 2025.
- Law Enforcement Access Transparency: While the vendor outlines general conditions under which personal information may be disclosed to comply with legal obligations, such as court orders or government requests, they do not provide detailed public guidelines specifically for law enforcement seeking access to customer data.
- Law Enforcement Access Transparency: While the vendor outlines general conditions under which personal information may be disclosed to comply with legal obligations, such as court orders or government requests, they do not provide detailed public guidelines specifically for law enforcement seeking access to customer data.
- Data Anonymisation Capabilities: Technical findings confirm that the vendor utilizes SI-19 (De-Identification) capabilities to reduce the risk of unauthorized disclosure,

which aligns with the bank's requirement for using authentic yet de-identified data for experimental services.

- Access Revocation SLAs: The vendor maintains a high maturity level for account termination, with a policy requirement to remove system access immediately if an employee is fired or within 24 hours for all other termination cases.
- Identity Lifecycle Management: Additional findings show that Grant LLC performs quarterly account reviews to validate a user's continued need for access, effectively mitigating "privilege creep" within the organization.

Management Policy and Procedures, following the NIST SP 800-30 guidelines for conducting risk assessments. The assessment findings—specifically highlighting the absence of an independent SOC 2 Type 2 report, the contract-dependent data destruction protocols, the ISO 27701 certification roadmap for April 2025, and the lack of explicit public guidelines for law enforcement data access—serve as a vital guide for CompanyX in enhancing its vendor risk management practices.

By implementing the recommended risk mitigation measures and leveraging the vendor's mature NIST SP 800-53 aligned controls—particularly their specialized SI-19 de-identification and AC-6 least privilege capabilities—CompanyX can significantly improve the security posture of this third-party relationship and effectively safeguard sensitive transaction data. CompanyX should refer to the detailed assessment report for a comprehensive analysis of the vendor's operational integrity, specific recommendations tailored to the FinTech connectivity project, and additional requirements necessary to maintain compliance within the highly regulated British banking sector.

Vendor Profile

Vendor Product & Service Information

Name of Vendor:	Grant LLC
Functionality: *Briefly describe the functionality of the products or services provided*	Grant LLC facilitates **seamless connectivity between internal banking systems and various external financial technology (FinTech) platforms**. The service is designed to support the practical implementation of shared data ecosystems by utilizing **de-identified yet authentic transaction data** for experimental procedures and integration testing within the highly regulated banking sector.

Purpose

This report assesses the **effectiveness of the management, operational, and technical security controls** implemented for **CompanyX**. It identifies relevant threats and vulnerabilities, evaluates the likelihood of exploitation, assesses the associated impact, and determines the overall risk level. The report documents the risk assessment activities conducted by **SecurityPal on 2026-03-01**. It provides a comprehensive understanding of the potential risks to CompanyX (a major British financial institution) in engaging with **Grant LLC** as a third-party product and service provider to facilitate connectivity with **various external financial technology platforms [Scenario, 1, 133].**

Vendor Assessment Scope of Work

SecurityPal conducted a security review for **Grant LLC**, primarily focusing on assessing their performance based on **CompanyX's Third-Party Security Standards** within the **Third-Party Management Policy.** The assessment of Grant LLC, which processes **de-identified yet authentic transaction data**, was evaluated based on the following controls as applicable to the connectivity services provided [Scenario, 1, 134]:

a) Information Security Policy Review of Grant LLC's formal suite of 10+ information security policies (e.g., COM-POL-AC-01, COM-POL-SI-03), which are formally approved by CISO Martin Luxon and undergo mandated annual review cycles.
b) Risk Assessment and Treatment Review of the Risk Assessment Policy (COM-POL-RA-16) and established programs that identify, assess, and monitor information and technology risks, including criticality analysis during the system development life cycle.
c) Operations Security Review of commercially reasonable practices designed to maintain operations security, including:
d) Technical testing: Effectiveness testing of incident response and simulations.
e) Protection against malicious software: Implementation of Malicious Code Protection (SI-3).
f) Network protection: Enforcement of Information Flow (AC-4) and Wireless Access (AC-18) security.
g) Technical vulnerability management: Systematic Flaw Remediation (SI-2) and security patching.
h) Logging and monitoring: Continuous System Monitoring (SI-4) and audit log reviews.
i) Incident response: Formal handling through the Incident Response Policy (COM-POL-IR-05).
j) Business continuity planning: Execution of Contingency Planning (COM-POL-CP-10) and alternate processing sites.
k) Access Control Review of the technical access control program, ensuring the enforcement of Least Privilege (AC-6), Separation of Duties (AC-5), and a revocation SLA of <24 hours upon termination.
l) Secure System Development Review of the secure development program, including role-based secure coding training for software developers (AT-3) and configuration change control processes.
m) Physical and Environmental Security Review of physical security controls per the Physical and Environmental Protection Policy (COM-POL-PE-04), covering facility access, visitor control, and environmental safeguards.
n) Human Resources Review of human resource processes, including criminal background and employment verification (COM-POL-PSP-14) for personnel accessing systems, and formal disciplinary sanction policies.
o) Compliance and Legal Review of applicable regulations relevant to the connectivity service. Criteria assessed include:
p) Protection of records: Adherence to Information Management and Retention (SI-12).

q) Privacy of PII: Implementation of specialized De-identification (SI-19) and Information Fragmentation (SI-23) to support the bank's experimental data needs.
r) Data deletion: Compliance with contract-based data destruction requirements.

Risk Assessment Approach

This risk assessment is conducted as per **CompanyX's Risk management policies and procedures and following NIST SP 800-30, Guide for Conducting Risk Assessments.** Risks were evaluated by considering threat events, their likelihood of occurrence, system vulnerabilities, mitigating factors, and the potential consequences/impact on the mission.

SecurityPal utilized a security questionnaire template to gather pertinent information for conducting a vendor security assessment. This questionnaire covers areas mentioned in Section "Vendor Assessment Scope of Work" of this report. Additionally, the following documents provided by the vendors were reviewed as a part of the assessment:

1. Vendor DDQ Survey
2. ISO 27001
3. MSA

SecurityPal also collected the necessary information by reviewing vendor websites, and security documentation and contacting the vendor's InfoSec & GRC teams for support as needed.

The following tables derived from CompanyX's Risk Management Policy were used to assign values to likelihood, impact, and risk:

Impact Levels and Description

Impact	**Impact Description**
Negligible(1)	A threat event could be expected to have no or negligible adverse effect.
Minor(2)	A threat event could be expected to have limited adverse effect, meaning: degradation of mission capability yet primary functions can still be performed; minor damage; minor financial loss; or range of effects is limited to some cyber resources but no critical resources.
Major(3)	A threat event could be expected to have an adverse effect, meaning: significant degradation of mission capability yet primary functions can still be performed at a reduced capacity; damage; financial loss; or range of effects is significant to some cyber resources and some critical resources.
Severe(4)	A threat event could be expected to have a significant adverse effect, meaning: severe degradation or loss of mission capability and one or more primary functions cannot be performed; major damage; major financial loss; loss of critical IP; or range of effects is extensive to

	most cyber resources and most critical resources
Catastrophic(5)	A threat event could be expected to have a catastrophic or critical adverse effect, meaning: complete degradation or loss of mission capability and several primary functions cannot be performed; critical damage; critical financial loss; or range of effects is catastrophic to most cyber resources and most critical resources. An example would include a compromise of an Azure root identity.

Likelihood Levels and Descriptions

Likelihood	Likelihood Description
Rare(1)	Adversary is highly unlikely to initiate a threat event. On a five-year event horizon, there is a less than 5% chance of this threat event transpiring.
Unlikely(2)	Adversary is unlikely to initiate a threat event. On a five-year event horizon, there is a 5-20% chance of this threat event transpiring.
Possible(3)	Adversary is likely to initiate a threat event. On a five-year event horizon, there is a 20-80% chance of this threat event transpiring.
Probable(4)	Adversary is highly likely to initiate a threat event. On a five-year event horizon, there is a 80-95% chance of this threat event transpiring.
Certain(5)	Adversary is certain to initiate a threat event. On a five-year event horizon, there is a greater than 95% chance of this threat event transpiring.

Risk Matrix

Risk = Likelihood * Impact		Likelihood				
		Certain (5)	Probable(4)	Possible(3)	Unlikely(2)	Rare(1)
Impact	Catastrophic(5)	25	20	15	10	5
	Severe(4)	20	16	12	8	4
	Major(3)	15	12	9	6	3
	Minor(2)	10	8	6	4	2
	Negligible(1)	5	4	3	2	1

Risk Levels and Descriptions

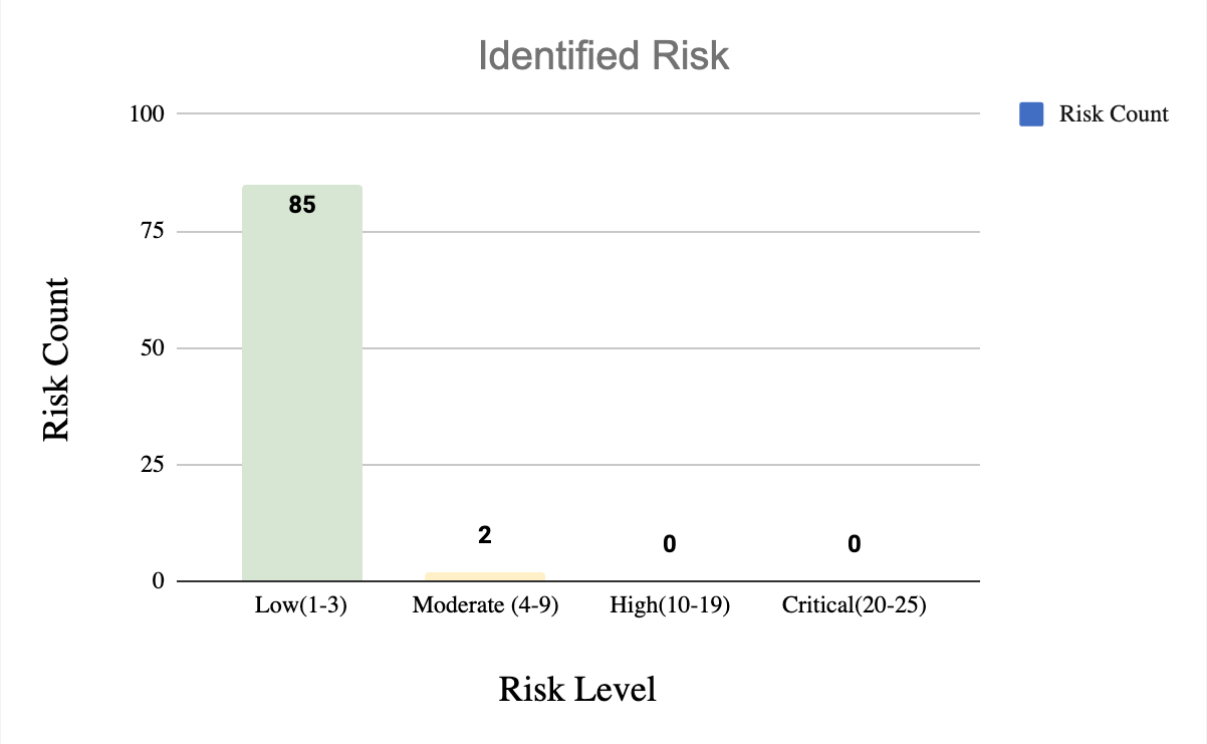
Risk Level	RIsk Description
Low (1-3)	A threat event could be expected to have a limited adverse effect on organizational operations, mission capabilities, assets, individuals, customers or other organizations.

Moderate (4-9)	A threat event could be expected to have a significant adverse effect on organizational operations, mission capabilities, assets, individuals, customers or other organizations.
High (10-19)	A threat event could be expected to have a significant adverse effect on organizational operations, mission capabilities, assets, individuals, customers or other organizations
Critical (20-25)	A threat event could be expected to have a critical adverse effect on organizational operations, mission capabilities, assets, individuals, customers or other organizations.

Risk Assessment Findings

SecurityPal performed the vendor risk assessment between CompanyX and **Grant LLC** on 2026-03-01**.** The majority of controls were found to be in alignment with CompanyX's Vendor Management Policy. However, no gaps were identified during the assessment.

Risk Level	Risk Count
Low(1-3)	85
Moderate (4-9)	2
High(10-19)	0
Critical(20-25)	0



Documentation Review

Required Document	Status	Vendor Comment	Exception Noted	Remarks
Data Processing Addendum (DPA)	Not uploaded	None	No exception noted.	None
ISO 27001	Uploaded	None	No exceptions noted.	None
MSA	Uploaded	None	Exception noted.	The MSA is yet to be signed by both parties.
SOW	Not Uploaded	None	No exceptions noted.	None
Pentest Report	Not uploaded	None	No exceptions noted.	None
SOC 2 Type 2	Not uploaded	None	No exception noted.	None
SOC 1 Type 2	Not uploaded	None	No exceptions noted.	None

Identified Risks

Risk	**#1**
Risk Description	The vendor does not include credit history checks in their screening process.
Likelihood	Possible (3)
Impact	Major (3)
Risk Level	Moderate (9)
Proposed Remediation	Implement comprehensive background checks encompassing credit assessments as part of the vendor's screening process to mitigate potential risks effectively.
Vendor's Comment	

Risk	**#2**
Risk Description	The vendor does not participate in globally recognized privacy programs.
Likelihood	Possible (3)
Impact	Major(3)
Risk Level	Moderate(9)
Proposed Remediation	The vendor does not participate in globally recognized privacy programs and has not obtained relevant certifications such as ISO/IEC 27701:2019 (Privacy Information Management System), GDPR (General Data Protection Regulation) Compliance, Privacy Shield, BS 10012:2017 (Personal Information Management), NIST Privacy Framework, and TrustArc (formerly TRUSTe). Participation in these programs and adherence to their standards can demonstrate commitment to data privacy and help manage privacy risks effectively.
Vendor's Comment	Presidio will add 27701 standard to our ISO 27001 certification during the next certification audit, starting in April 2025. Outside counsel is being consulted to review new and current documents to reflect this standard.

Exceptions Noted

- The vendor has mentioned that the parent company is SOC 2 Type 2 compliant. However, they have not provided the SOC report.
- It is mentioned that the data will not be destroyed on demand by the client but will be destroyed as per what is agreed in the client contract.
- The vendor does not participate in any privacy program or certification. However, the 27701 standard in ISO 27001 certification is on the roadmap during the next certification audit, starting in April 2025.
- Additionally, the vendor does not specifically mention public guidelines for law enforcement seeking access to customer data. It outlines the conditions under which personal information may be disclosed, including compliance with legal obligations such as court orders and government requests. However, it does not provide detailed public guidelines for law enforcement access.
- The MSA is yet to be signed by both parties.

Additionally, the vendor did not submit the following documents:

1. Data Processing Addendum (DPA)
2. Mutual NDA
3. Order Form
4. Quote
5. Pentest Report
6. SOC 1 Type 2
7. SOC 2 Type 2
8. SOW

Recommendation

After conducting a comprehensive review of Grant LLC on 2026-03-01**,** it is evident that the vendor is aligned with the specific business requirements and goals of CompanyX. The vendor has demonstrated cooperation by providing the required assessment documents and additional resources regarding its IT policies and practices.

After a thorough risk assessment, **it is recommended that CompanyX approve the vendor as their offerings are aligned** with CompanyX's needs, and the identified risks can be effectively managed through strategic mitigation measures.

Conclusion

In conclusion, majority controls are aligned with CompanyX's Third Party Security Standards within the Third-Party Management Policy. As a result of the assessment**, we identified two specific gaps. Both the sub-controls are classified as having a moderate risk level.** We have provided appropriate recommendations to mitigate these risks effectively. **The vendor risk assigned to Grant LLC is classified as Low, considering the nature of the products, services, and identified risk factors.** By adhering to the assessment findings and recommendations, CompanyX can strengthen its vendor risk management practices and ensure the security of its systems and data.

CompanyX is encouraged to refer to the detailed assessment report for a thorough analysis, tailored recommendations for each risk, and any additional requirements specific to the services provided.